

docs/modules/audit-log.md

AuditLog (Аудит журнали) - SPEC

Мақсад

QBO Audit Log паритети: тизимда КИМ, ҚАЧОН, НИМА қилганини кўрсатувчи ўзгармас (append-only) ҳодисалар журнали. GL'га таъсир қилган ҳар бир ҳаракат, кириш уринишлари ва фойдаланувчи бошқаруви USERS соҳали ролларга (амалда SUPER_ADMIN) битта экранда кўринади.

Эталон изоҳи: Audit Log - QBO'нинг ПРОГРАММА хусусияти, Finance.xsd'да entity эмас (docs/qbo-reference'да йўқлиги текширилди). Солиштирув учун QBO экран хулқи олинди: ҳодисалар рўйхати (Date changed / User / Event), филтрлар (User, Date, Events), тарих ўчирилмаслиги.

Дизайн қарори - нега ҳодиса журнали, entity-diff эмас

Икки йўл бор эди: (а) Envers услубида ҳар entity'га _AUD жадвал (before/after diff), (б) QBO услубида бизнес-ҳодисалар журнали. (б) танланди:

- POSTED ҳужжат ўзгармайди (темир қоида 3) - «ўзгариш тарихи» бизда деярли бутунлай яратиш + сторно, diff'га материал оз;
- Envers 30+ жадвални икки баробарлайди, ddl-auto=validate + Liquibase тартибига оғир юк;
- QBO ҳам фойдаланувчига ҳодиса тилида кўрсатади, diff фақат «View» тафсилотида (бизда 2-босқич).

Entity'лар

`audit_event` (changeset `034-audit-log.sql`), BaseEntity майдонларига қўшимча:

майдон	тип	изоҳ
username	varchar(50) NOT NULL	ҳаракат эгаси; LOGIN_FAILURE'да уринилган username; auth контексти йўқ жараёнларда <code>system</code>
event_type	varchar(40) NOT NULL	AuditEventType enum (STRING)
entry_id	uuid NULL, FK journal_entry	GL ҳодисаларида тегишли JE
doc_number	varchar(30) NULL	JE entry_number снапшоти - экранда JOIN'сиз кўрсатиш учун
details	varchar(500) NULL	одам ўқийдиган тафсилот (JE description, қулф муддати...)
ip_address	varchar(45) NULL	фақат auth ҳодисаларида (IPv6 сиғади)

- Индекслар: `created_at DESC` (рўйхат), `event_type`, `username`.
- Ҳодиса вақти = `created_at` (UTC, қоида 12; экранда Fmt.dt). Бир транзакция ичидаги тартиб id (uuid7) билан - курс тарихи нақши.
- `username` алоҳида устун (createdBy UUID'ига қарамай): LOGIN_FAILURE'да authenticated principal йўқ (createdBy null бўлади), уринилган username'га жой керак; қолган ҳолларда ҳам экран JOIN'сиз ўқийди.
- ЎЗГАРМАС: update/delete йўқ - на UI'да, на service'да. Super admin ҳам ўчира олмайди (аудит изи маъноси шу).

`AuditEventType` (MVP): `JE_POSTED` , `JE_REVERSED` , `LOGIN_SUCCESS` , `LOGIN_FAILURE` , `LOCKOUT` , `USER_CREATED` , `USER_UPDATED` , `PASSWORD_CHANGED` .

Ёзиш нуқталари (ким қандай ёзади)

Икки механизм - иккиси ҳам сабабли:

1. **Ledger ҳодисалари - Spring application event орқали.** Қоида 6: `ledger` ҳеч кимга боғлиқ эмас, демак `PostingService` `AuditLogService`'ни чақира олмайди. Ечим: `PostingService` ўзининг event'ини эълон қилади (record'лар `ledger.service` ичида туради - `ledger`'га янги dependency қўшилмайди), `audit` модули тинглайди: - `createAndPost` муваффақиятли якунида `JournalEntryPostedEvent(entry)` ; - `reverse`'да `JournalEntryReversedEvent(reversal, original)` ; - `audit` модулида `@EventListener` СИНХРОН, ўша транзакцияда - `rollback` бўлса аудит ёзуви ҳам йўқолади (журнал фақат ҳақиқатан содир бўлган ишни акс эттиради); - битта нуқта = тўлиқ қамров: `invoice`, `bill`, `payment`, `bank txn`, `transfer`, `inventory`, `landed cost`, `opening balance`, қўлда `JE` - ҳаммаси `PostingService`'дан ўтади (қоида 2).
2. **Auth/user ҳодисалари:** - `LOGIN_SUCCESS` / `LOGIN_FAILURE`: `audit` модулидаги алоҳида `listener` `Spring Security`'нинг ўз event'ларини тинглайди (`AuthenticationSuccessEvent` / `AuthenticationFailureBadCredentialsEvent` / `AuthenticationFailureLockedEvent` / `AuthenticationFailureDisabledEvent` - `LoginAttemptListener` нақши, `security` модулига ТЕГИЛМАЙДИ). Учала хато уриниш ҳам битта `LOGIN_FAILURE` - сабаб `details`'да фарқланади («Нотўғри парол билан уриниш» / «Қулф даврида уриниш» / «Нофаол ҳисобга уриниш»); шу туфайли қулф давридаги уринишлар ҳам журналда кўринади. IP - event ичидаги `WebAuthenticationDetails`'дан. - `LOCKOUT`: `LoginAttemptListener` қулф қўйган жойда `AuditLogService.record(...)` тўғри чақиради (`security` → `audit` боғлиқлик рухсатли, цикл йўқ: `audit security`'ни `import` қилмайди). - `USER_CREATED` / `USER_UPDATED` / `PASSWORD_CHANGED`: `UserService` ва `ProfileController`'дан тўғри чақириқ.

Service API

- `AuditLogService.record(type, username, entryId, docNumber, details, ip)` - ягона ёзиш йўли (`append-only`). Бошқа модуллар фақат шуни кўради.
- `AuditLogService.page(filter, pageable)` - экран учун: сана оралиғи, `event_type`, `username` филтрлари, янгидан эскига.

Posting

GL'га ёзмайди - `posting-rules.md` ЎЗГАРМАЙДИ (аудит модули проводка қилмайди, фақат кузатади).

Валидация ва инвариантлар

- BR-* кодлари ЙЎҚ ва киритилмайди: фойдаланувчи буза оладиган қоида йўқ - экран `read-only`, ёзувни тизим ўзи киритади (`docs/business-rules.md` ўзгармайди).
- Инвариант: `append-only` - `update/delete` API умуман мавжуд эмас.
- `event_type` фақат `enum` қийматлари (`STRING` + `NOT NULL`).

Тестлар (мажбурий рўйхат)

1. `Transfer` (ёки `invoice`) `post` → `JE_POSTED` ёзуви: `entry_id`, `doc_number`, `username` тўғри.

2. Reverse → JE_REVERSED, details'да original entry рақами.
3. Rollback исботи: post'дан кейин атайлаб exception → на JE, на audit ёзуви қолади (синхрон same-tx listener текшируви).
4. LOGIN_FAILURE ёзилади; бўсағада LOCKOUT ёзуви (LoginAttemptListener тести кенгаяди).
5. USER_CREATED / PASSWORD_CHANGED ёзилади.
6. /audit-log: USERS соҳали роль (SUPER_ADMIN) 200, соҳасиз роль 403 (ScreenSmokeTest).
7. Фильтр: event_type + сана оралиғи тўғри кесади.

Экранлар (JTE routes)

- **GET /audit-log** - USERS соҳаси (user-roles.md; амалда SUPER_ADMIN). Жадвал устунлари: Вақт (Fmt.dt, компания TZ) | Фойдаланувчи | Ҳодиса (i18n: **audit.event.JE_POSTED** ...) | Хужжат (doc_number; entry_id бор бўлса /journal-entries/{id} линк) | Тафсилот.
- Фильтрлар GET параметрлар: from/to сана, event_type select, username. Пагинация page/size (default 50), янгидан эскига - янги экран нолдан Pageable (PERF-perf1 master'ига зид эмас).
- Сайдбар: Созламалар гуруҳида «Аудит журнали», USERS соҳаси кўринадиган ролларга (сайдбар соҳа филтри - Perms, 092).
- Мобил: .table-wrap, 375px'да ишлайди.

Кенгайиш (фойдаланувчи тасдиғи - DEC-062)

Фойдаланувчи талаби: «барча ўзгаришлар кўриниши керак - ким, нима, қайси IP, қайси client'дан».

Янги ҳодиса турлари (enum'га қўшилади, i18n уч тилда):

Тип	Манба	details намунаси
SETTINGS_CHANGED	CompanySettingsService.update (shared ўз event'ини эълон қилади, audit тинглайди - ledger нақши, цикл йўқ)	«closingDate: →» - фақат ЎЗГАРГАН майдонлар
FACTORY_RESET	FactoryResetService	reset ичида TRUNCATE'дан KEYIN ёзилади - тоза журналнинг биринчи ёзуви бўлиб қолади
IMPORT_EXCEL	ExcellImportService.apply	«яратилди: 12 контакт, 34 товар; ўтказилди: 3»
CHART_IMPORTED	AccountService.importDefaultChart	«яратилди N, ўтказилди M» (қўлда тугма ва авто-init иккиси)
LOGOUT	Spring Security logout success handler	-
ACCOUNT_CREATED / ACCOUNT_UPDATED / ACCOUNT_DEACTIVATED	AccountService	счёт номи + detail type; таҳрирда ўзгарган майдонлар
PLUGIN_TOGGLED	PluginService.setEnabled (DEC-113; shared ўз event'ини эълон қилади - SETTINGS_CHANGED йўли)	«TELEGRAM: ёқилди» / «TELEGRAM: ўчирилди» - фақат ҳолат ростдан ўзгарганда
TELEGRAM_TOKEN_CHANGED	TelegramService.saveToken/deleteToken (DEC-103, security модули - AuditLogService'ни ТЎҒРИДАН чақиради: UserService/LoginAttemptListener прецеденти, security → audit рухсатли)	«Bot token янгиланди: @botname» / «Bot token ўчирилди» - ФАҚАТ факт, токеннинг ЎЗИ (маскаланган ҳолда ҳам) ЁЗИЛМАЙДИ
EXCHANGE_RATE_IMPORTED	ExchangeRateScheduler.importDaily (DEC-164; CBU авто-fetch cron 10:00/16:00 Тошкент; shared ExchangeRateImportedEvent эълон қилади - PLUGIN_TOGGLED йўли)	муваффақият «N валюта янгиланди, M ўтказилди»; хато «амалга ошмади: <сабаб>» - actor «Тизим» (фон жараён, auth йўқ); listener REQUIRES_NEW - хато импортнинг txn rollback'и аудитни ютмайди

IP ва client: `ip_address` энди ҲАММА ҳодисага ёзилади (web контекста - RequestContextHolder орқали; фон жараёнда null) + янги `user_agent varchar(255)` устун (changeset 050) - браузер қатори қисқартирилиб. Экранда Тафсилот устунда кўринади.

Retention ҚАРОРИ (фойдаланувчи саволига жавоб): аудит ЎЧИРИЛМАЙДИ - QBO ҳам ўчирмайди; молия аудити айнан «ҳеч ким ўчира олмаслиги» учун қимматли - «эскисини ўчириш» тугмаси из ўчиришга йўл очарди. DB нагрузка: append-only INSERT posting'нинг ёнида арзимас; кичик бизнес ҳажмида йилига ~100 минг сатргача - муаммосиз. Жадвал йиллар давомида жуда катталашса - АРХИВЛАШ (export + кўчириш, ўчириш эмас) 2-босқичда.

2-босқич (ҳозир ЭМАС - алоҳида келишилади)

- Контакт/товар/tax rate таҳрирлари (CATALOG_* давоми);

- Estimate/PO ҳодисалари (GL'сиз ҳужжатлар);
- Attachment юкланди/ўчирилди;
- before/after diff («View» тафсилоти, QBO услуги);
- АРХИВЛАШ сиёсати: жадвал жуда катталашганда эски ёзувларни export қилиб алоҳида сақлаш (ўчириш ЙЎҚ - юқоридаги қарор).